# Data Governance, Compliance and Ethics



Lecture 04: PRIVACY AND DATA PROTECTION (PART 2)

Jaswinder.singh@ncirl.ie

# Overview of course content

1. Data Governance and Management (Weeks 1-3)
2. Privacy and Data Protection (Weeks 4-6)
3. Ethical Issues Pertaining to Data (Weeks 7-9)
4. Fairness, Accountability, and Transparency of Algorithmic Systems (Weeks 10-12)

# Agenda

***The Right to Privacy***
- European Data Protection Origins
- Brief history of human rights
- Concept of Privacy, examples of threats to privacy
- Types of EU Legislation
- The right to privacy in national law, Universal declaration of human rights, European Convention on Human Rights, EU Charter of Fundamental Rights

***Data Protection Regulation Scope***
- Irish Data Protection Commission
- Data Protection Regulation Scope
- Key Provisions in the GDPR (Material Scope, Personal Data, Processing, Data Controller and Processor (roles and responsibilities), Data Protection Principles, Data Subject Rights, Privacy by Design and by Default, Legitimate Bases for processing, Record of processing activities, Informed Consent)

***Data Protection In Practice***
- Data Transfer to Third Countries
- Surveillance including CCTV
- Privacy and regulatory compliance issues pertaining to specific sectors (Cloud Computing)
- Data Anonymization
- EU Digital Agenda

# Data Protection Commission (DPC)

An Coimisiún um Chosaint Sonraí
Data Protection Commission

- The DPC is the Irish supervisory authority for the GDPR, and also has functions and powers related to other important regulatory frameworks
- It was established by the Data Protection Acts 1988 to 2018. (Part 2, DPA 2018)
- Under the GDPR and the Data Protection Acts, the DPC is **responsible for monitoring the application of the GDPR**.
- The DPC's tasks include:
  - Monitoring and enforcing the application of the GDPR,
  - Promoting awareness and understanding of GDPR,
  - Providing information to and handling complaints of data subjects, and
  - Cooperating with other data protection authorities in other EU Member States. (Art.57 GDPR, s.12 DPA 2018)

# EU and Irish legal protection

From 25 May 2018, the data protection frameworks are:

## EU law

- Directive 2002/58/EC (2002) on the processing of personal data and the protection of privacy in the electronic communications sector (**ePrivacy Directive**); amended by Directive 2009/136/EC
- General Data Protection Regulation (**GDPR**)
- The "**Law Enforcement Directive**" (Directive (EU) 2016/680) which has been transposed into Irish law by way of the Data Protection Act 2018

## Irish legislation

- Ireland's '**ePrivacy Regulations**' (S.I. 336/2011, which implemented the EU 'ePrivacy Directive')
- Data Protection Acts (**DPA) 1988 and 2003**
- Data Protection Act (**DPA) 2018**



**EU law is superior to national law**

- Irish law cannot contradict EU laws
- EU law can over-rule an Irish law
- EU law has a direct effect on its citizens (court)

Source: https://www.dataprotection.ie/en/who-we-are/data-protection-legislation

# Data Protection Regulation Scope

An Coimisiún um Chosaint Sonraí
Data Protection Commission

| | |
|---|---|
| GDPR | The GDPR **will apply by default to the majority of personal data processing**, but in Ireland **further rules** on certain issues (for example the reasons for, and extent to which, data subject rights may be restricted) **are set out in the DPA 2018.** |
| | |
| | |
| | |
| | |

https://www.dataprotection.ie/en/who-we-are/data-protection-legislation

# Data Protection Regulation Scope

An Coimisiún um Chosaint Sonraí
Data Protection Commission

| | |
|---|---|
| GDPR | The GDPR **will apply by default to the majority of personal data processing**, but in Ireland **further rules** on certain issues (for example the reasons for, and extent to which, data subject rights may be restricted) **are set out in the DPA 2018**. |
| Law Enforcement Directive (as transposed by provisions in Parts 5 and 6 of the Data Protection Act 2018) | The Law Enforcement Directive **is transposed into Irish law by the DPA 2018**, in Part 5 and Part 6 of that Act. Those provisions set out the laws in Ireland which apply **concerning the processing of personal data by data controllers who are competent for the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties**, where personal data is being processed for these purposes. |
| Data Protection Acts 1988 and 2003 (as retained by sections 7(4) and 8 of the DPA 2018) | The Data Protection Acts 1988 and 2003 (without the repeals and revocations in section 7 the Data Protection Act 2018) apply to:<br>• **Ongoing investigations** by, **and complaints** to, the Data Protection Commissioner **commenced or made before 25 May 2018**;<br>• New **complaints** and potential contraventions of the DPAs 1988 and 2003 which **arose prior to the 25 May 2018 but** which are made or **investigated on or after 25 May 2018**; and<br>• Processing of personal data under the **Criminal Justice** (Forensic Evidence and DNA Database System) Act 2014 **or** the **Vehicle Registration Data** (Automated Searching and Exchange) Act 2018. |
| Data Protection Acts 1988 and 2003 (as amended by section 7 of the Data Protection Act 2018 | The Data Protection Acts 1988 and 2003 (as amended by the repeals and revocations in section 7 the Data Protection Act 2018) apply to: Complaints and potential contraventions of data protection law **concerning the processing of personal data for the purposes of safeguarding the security of the State, the defence of the State or the international relations of the State** (as per section 8(1)(a) of the DPA 2018). |
| ePrivacy Regulations | From 25 May 2018, **processing of personal data in the context of certain electronic communications** (including, amongst other things, unsolicited electronic communications made by phone, e-mail, and SMS) is subject to both the general laws set out in the GDPR and the specific laws set out in the "ePrivacy Regulations" (S.I. No. 336 of 2011, under which the ePrivacy Directive 2002/58/EC (as amended by Directive 2006/24/EC and 2009/136/EC) was transposed into Irish law). |

# ePrivacy Regulation (1/2)

- The current ePrivacy Directive ePD (2002/58/EC) came into effect in July 2002, known as **the 'cookies law'**
- In January 2017, the European Commission proposed a new Regulation on Privacy and Electronic Communications: ePrivacy Regulation (ePR) which aims to ensure privacy in all electronic communications

- The regulation will cover:
- The **content and metadata** relating to electronic communications in both transmission and provision of services;
- Information related to **processing, emitting and storage** of end users' terminal equipment;
- The retrieval and presentation of information on the internet by placing software that allows for electronic communications;
- Publicly available directories of end user's information captured through electronic communication services; and
- Sending or presenting **direct marketing communications** to end users.






http://www.irishstatutebook.ie/eli/2011/si/336/made/en/print

# ePrivacy Regulation (2/2)

- The regulation covers:
- **Cookies**
  - Rules around cookies and consent clearer and more user friendly
  - Responsibility for obtaining consent and penalties
- **Adtech**
  - End user consent will be required for all direct marketing communications
  - Withdrawal of consent should be as easy as consenting
- **Medtech**
  - Rules around electronic communications metadata



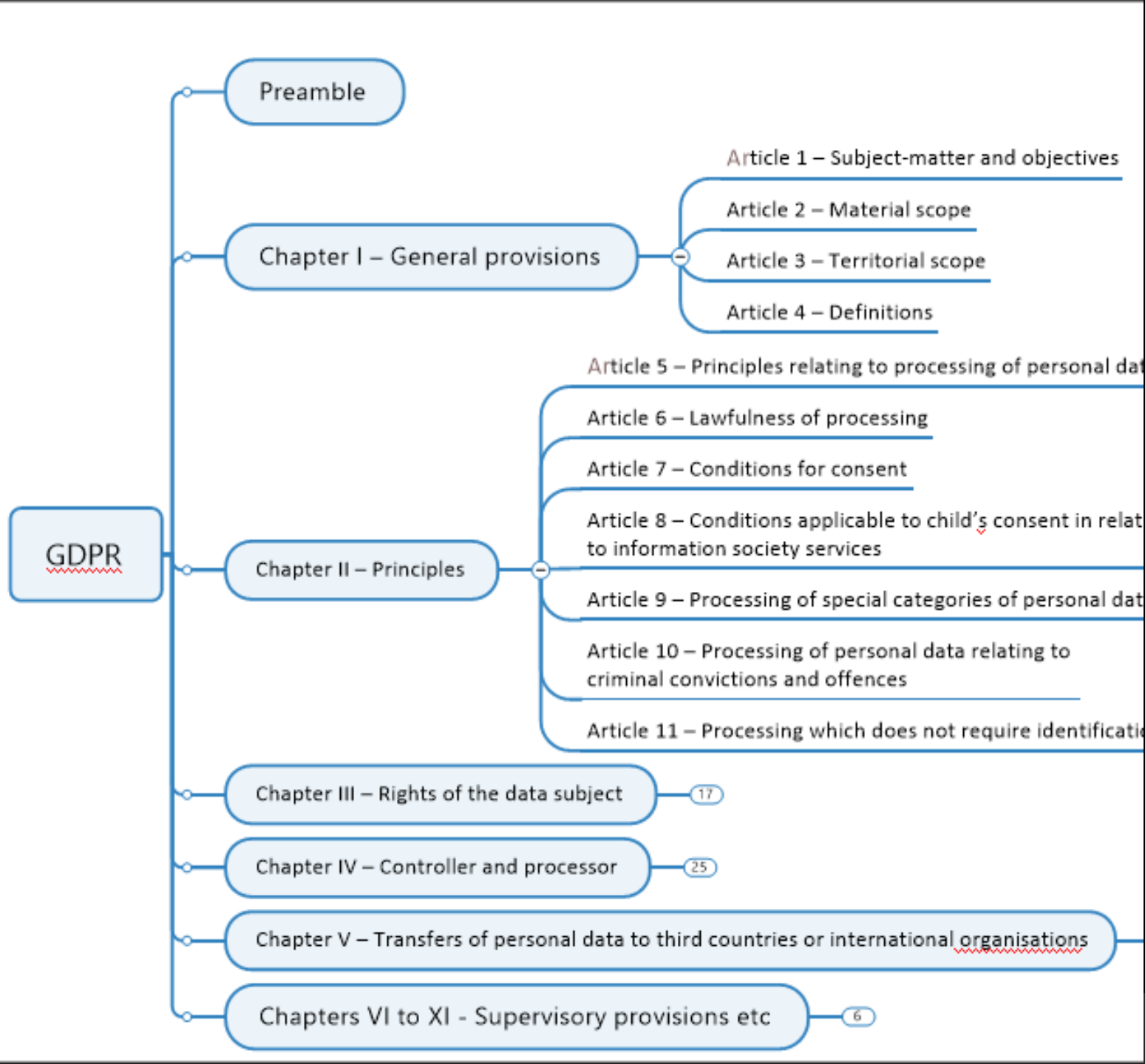
http://www.irishstatutebook.ie/eli/2011/si/336/made/en/print

# The General Data Protection Regulation (GDPR)

- came into **effect in 25 May 2018** to replace the Data Protection Directive 1995
- harmonize data privacy laws across Europe
- applies to all organizations that handle personal data of EU residents
- **adds new rights to individuals & new obligations to organizations (data controllers and processors)**
- **can impose fines** up to €20 million or 4% of global turnover



# Visual representation of GDPR Structure (Part)



# National Law (Ireland)

- Although the GDPR is directly applicable as a law in all Member States, it allows for certain issues to be given further effect in national law.
  - E.g., Age of digital consent
- In Ireland, the national law, which, amongst other things, gives further effect to the GDPR, is the Data Protection Act 2018
  - Establishment of national Data Protection Commission
  - Establishment of fees, definition of children, etc.
  - Processing of special categories of personal data and processing of personal data relating to criminal convictions and offences




Data Protection Act 2018

# GDPR Exemptions




- In some instances, depending on
  - **the nature and circumstances** of the personal data processing,
  - **the type** of personal data being processed,
  - or **when** the data protection issue occurred,

the GDPR will not apply and instead another legal framework concerning the regulation of the processing of personal data may apply.




- For example
  - if a data protection complaint or a possible infringement of the law relates to an incident **which occurred before the GDPR**

    ➔ the Data Protection Acts 1988 – 2003
  - After 25 May 2018, if the processing of personal data is carried out **for a law enforcement purpose**

    ➔ The Law Enforcement Directive, which has been transposed into Irish law by way of the DPA 2018



# Scope of the GDPR

Articles 1-3 cover the applicability of the GDPR



*Article 1*

**Subject-matter and objectives**

1. This Regulation lays down rules relating to the protection of natural persons with regard to the processing of personal data and rules relating to the free movement of personal data.

2. This Regulation protects fundamental rights and freedoms of natural persons and in particular their right to the protection of personal data.

3. The free movement of personal data within the Union shall be neither restricted nor prohibited for reasons connected with the protection of natural persons with regard to the processing of personal data.

# Scope of the GDPR

*Article 2*

**Material scope**

1. This Regulation applies to the processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which form part of a filing system or are intended to form part of a filing system.

2. This Regulation does not apply to the processing of personal data:




(a) in the course of an activity which falls outside the scope of Union law;

(b) by the Member States when carrying out activities which fall within the scope of Chapter 2 of Title V of the TEU;

(c) by a natural person in the course of a purely personal or household activity;

(d) by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security.

3. For the processing of personal data by the Union institutions, bodies, offices and agencies, Regulation (EC) No 45/2001 applies. Regulation (EC) No 45/2001 and other Union legal acts applicable to such processing of personal data shall be adapted to the principles and rules of this Regulation in accordance with Article 98.

4. This Regulation shall be without prejudice to the application of Directive 2000/31/EC, in particular of the liability rules of intermediary service providers in Articles 12 to 15 of that Directive.

# Case Study 1 – Material Scope of the GDPR

Article 2 of the GDPR states that the GDPR doesn't apply to a "*purely personal or household activity.*":

Recital 18 of the GDPR provides some examples of personal and household activities:

- Personal correspondence
- Keeping an address book
- Social networking (as a private individual)

**Rynes v Czech Office for Personal Data Protection**

The case involved Mr. Rynes, who had set up security cameras in his garden. The cameras were designed to monitor his property but also filmed part of a public area.



**The Czech Data Protection Authority fined Mr. Rynes for filming members of the public without their consent**. Mr. Rynes appealed, arguing that he was covered by the personal and household activities exemption.

The court decided that although the filming was for private purposes, it involved people that were not part of Mr. Rynes' private life. Therefore, **Mr. Rynes was not covered by the exemption and had to comply with the GDPR.**

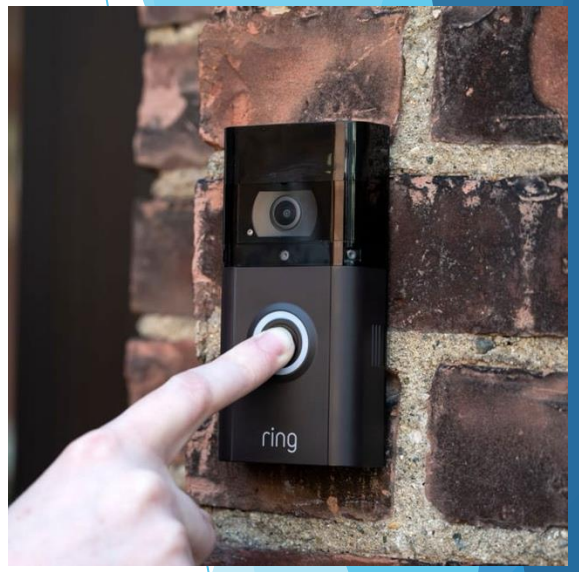


http://curia.europa.eu/juris/document/document.jsf?docid=160561&doclang=EN

# Case Study 2 – Material Scope of the GDPR

**UK Ring doorbell court case**

Camera doorbells allow you to see who is at your door when they press the button - as well as detecting motion.




Dr Mary Fairhurst said she had to move out of her home because of the doorbell installed by neighbour Jon Woodard.

Mr Woodward had a Ring doorbell attached to the front door of his home in addition to a number of home security video devices set up around his home..

**At the end of a court hearing Judge Melissa Clarke said that:**

- Mr Woodward's use of the smart doorbell device and other personal CCTV items had breached data protection laws
- the images and video of Dr Fairhurst are her personal data
- Mr Woodard had breached the Data Protection Act 2018 and UK GDPR and now faces a compensation fine of up to £100,000 for this breach





https://www.scotsman.com/business/consumer/ring-doorbell-is-the-smart-camera-doorbell-a-breach-of-privacy-uk-ring-doorbell-court-case-explained-3420662

# Material Scope of the GDPR - DPC Ireland

## I have a video doorbell that I can monitor on my smartphone – does that make me a data controller?

Similar to the cameras inside the home, a smart doorbell is likely to fall within the domestic exemption as its use will be connected purely with the homeowner's personal or household activity.

Where this may differ from the previous scenario is if the camera on the doorbell is pointed towards a publicly accessible area and is capable of recording individuals in that area.

The Court of Justice of the European Union has established in the case of 'Ryneš' that the use of a domestic CCTV system that covers a public space falls within the scope of data protection law.

To avoid this, when installing a smart doorbell care should be taken to avoid taking in a publicly accessible area. If this can't be avoided, a user should consult our guidance on CCTV systems to understand their transparency obligations.

Similarly, the definition of 'personal data' only covers information (in this case a video recording) where people are identified or identifiable.

What this means is any video footage which captures images of people where they can't actually be identified wouldn't be personal data at all. For example, the doorbell would probably capture a pretty clear picture of the person at the door, but might be designed or positioned so that any images of people on a public street are too obscured or low-quality to actually identify them.






http://curia.europa.eu/juris/document/document.jsf?docid=160561&doclang=EN

# Scope of the GDPR



*Article 3*

**Territorial scope**

1. This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.

2. This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to:

(a) the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union; or

(b) the monitoring of their behaviour as far as their behaviour takes place within the Union.

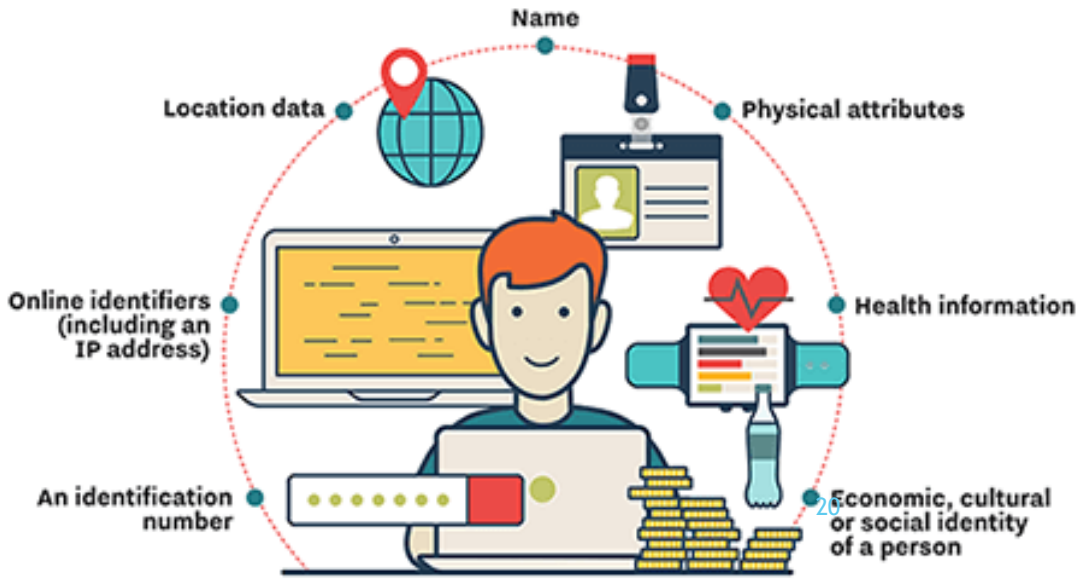
3. This Regulation applies to the processing of personal data by a controller not established in the Union, but in a place where Member State law applies by virtue of public international law.

# PERSONAL DATA

Art 4(1)

Personal data is **any information belonging to an identified or identifiable natural person**, i.e. an individual could be identified with directly or indirectly with these data.

> a name, an identification number, location data, an online identifier, or factors such as physical, physiological, genetic, mental, economic, cultural or social that may lead to identifying a person.



# PERSONAL DATA

## WHAT IS AND WHAT IS NOT CONSIDERED PERSONAL DATA + SPECIAL CATEGORY

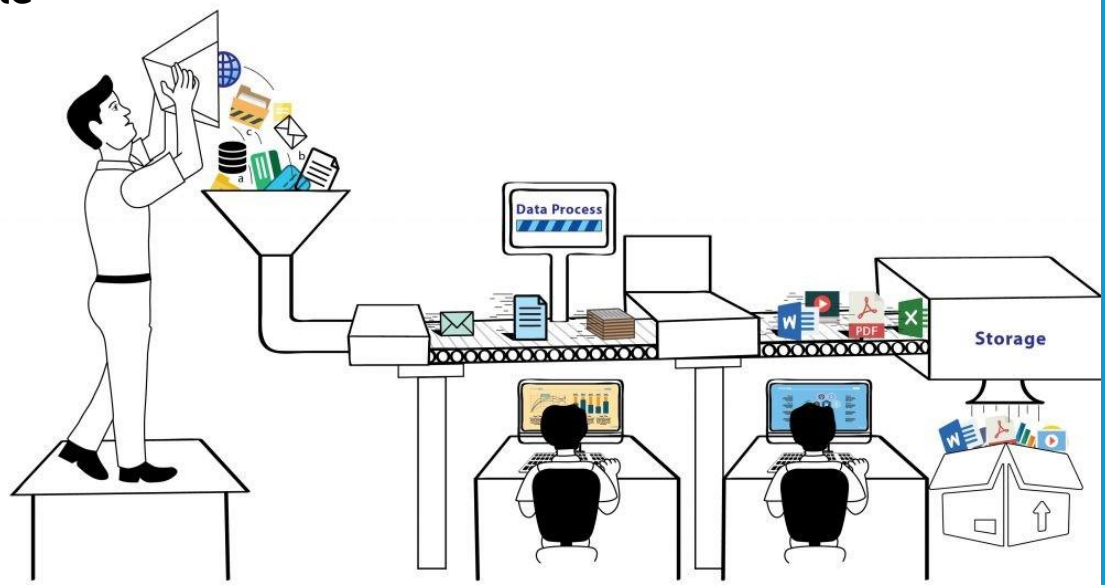
| PERSONAL DATA | SPECIAL CATEGORIES | NOT PERSONAL DATA |
| --- | --- | --- |
| • name<br>• email address (name.surname@domain.com)<br>• phone number<br>• Internet Protocol (IP) address<br>• home address | • criminal records<br>• personal data related to racial or ethnic origin<br>• medical records<br>• religious or philosophical beliefs<br>• trade-union membership<br>• blood type<br>• political stands... | • a company registration number;<br>• an email address as info@company.com<br>• anonymiZed data<br>• information about legal entities<br>• data related to a deceased individual |

# PROCESSING

Art 4(2). Any operation which is performed on personal data such as:

- Collection
- Organisation
- Storage
- Alteration
- Alignment Or Combination
- Use
- Erasure Or Destruction
- Restriction
- Recording
- Structuring
- Adaptation
- Retrieval Or Consultation
- Disclosure By Transmission, Dissemination Or Otherwise Making Available

Pseudonymised data is also in scope, while anonymized data is not.



# CONTROLLER vs. PROCESSOR

**Art. 24-43**

**Controller**: Any natural or legal person, public authority, agency or other body which alone or jointly with others determined the purposes and means of the processing of personal data.



- Responsible for managing the use of data
- Defines the how and why of personal data processing

**Processor**: A natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller.



- Responsible for carrying out the actual processing
- Needs to maintain an audit trail of al processing activities

# Key Data Protection Provisions in GDPR w.r.t. data protection measures

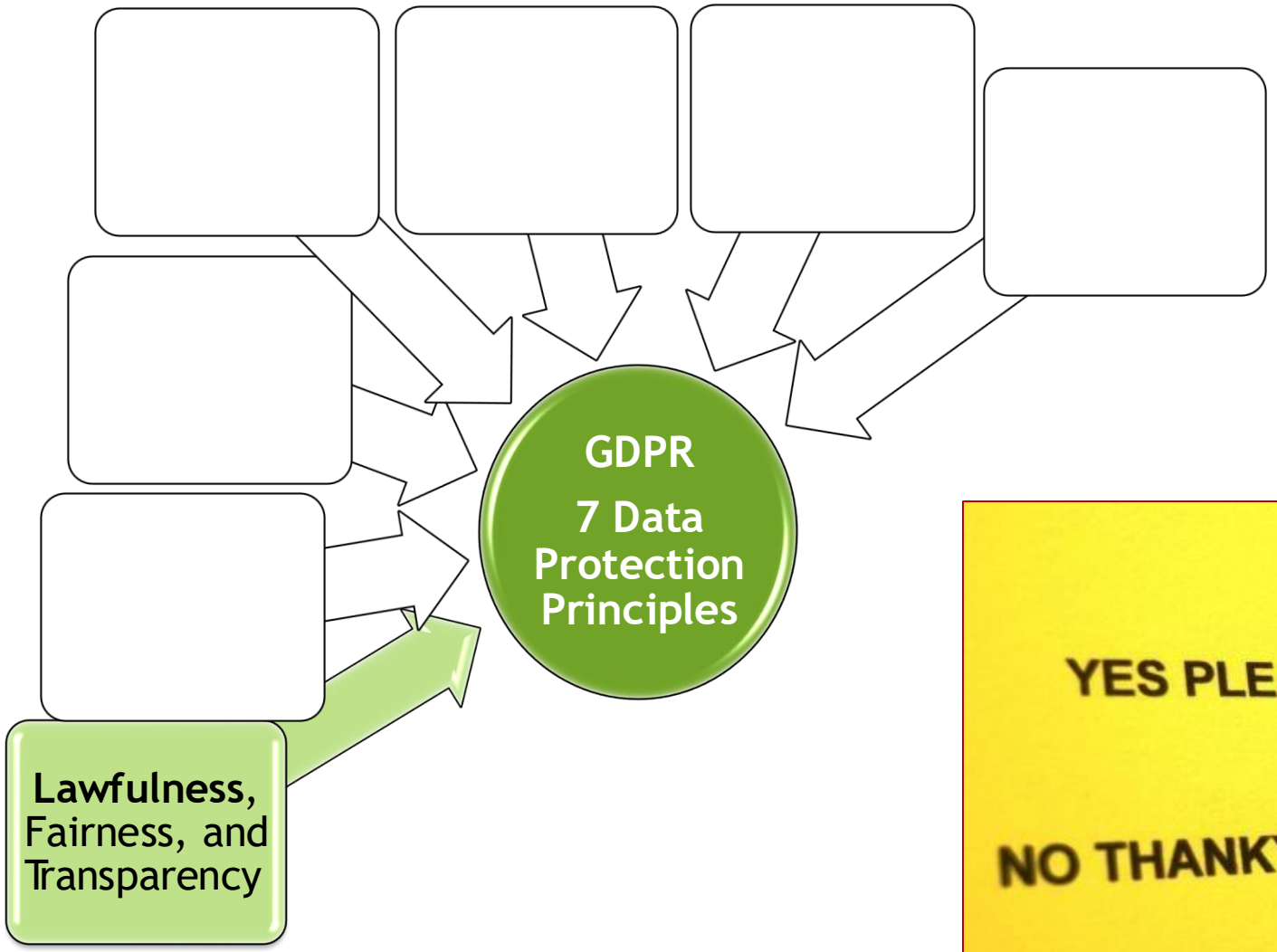
- Data Protection Principles (Art. 5)
- Data Subject Rights (Art. 13-22)
- Privacy by Design and By Default –PbD (Art. 25)

# Principles Relating To Processing Of Personal Data

Art. 5-11 Data Protection Principles (DPRs)

| |
|---|
| 1. Lawfulness, Fairness, and Transparency |
| 2. Purpose limitation |
| 3. Data minimization |
| 4. Accuracy |
| 5. Storage limitation |
| 6. Integrity and Confidentiality |
| 7. Accountability |

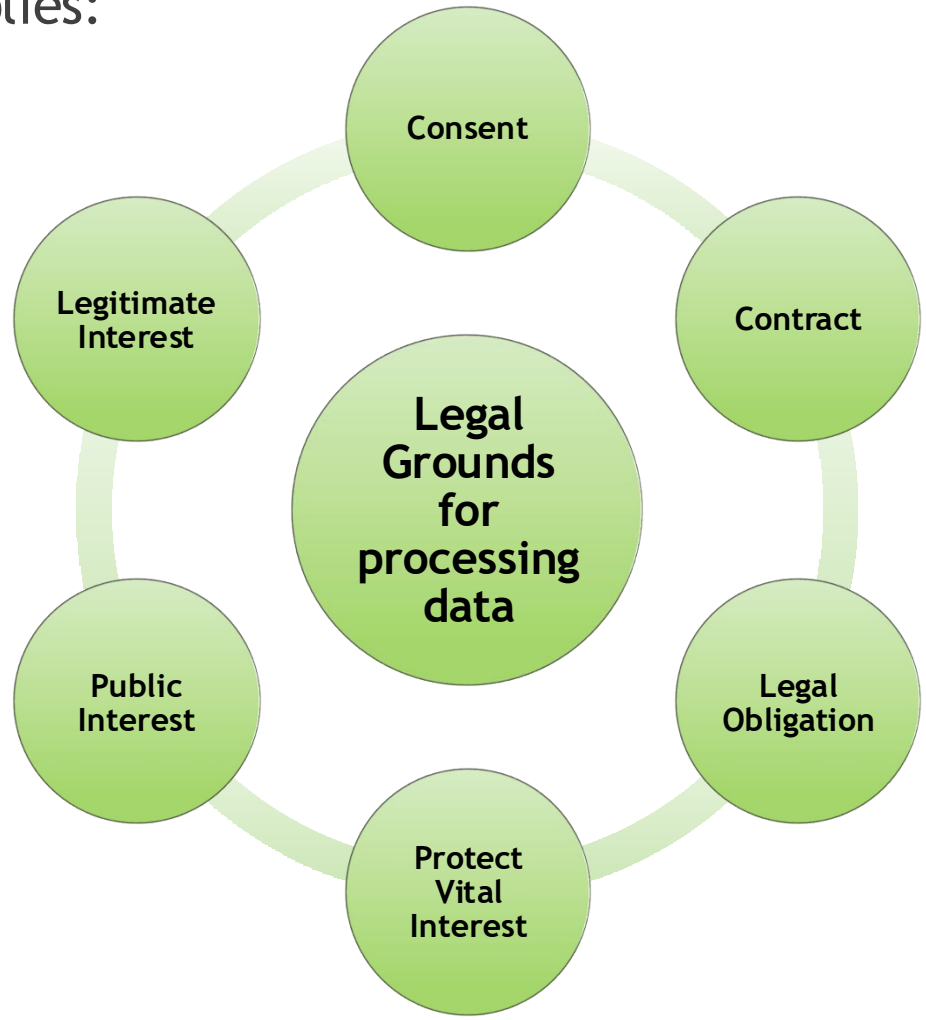
# GDPR Data Protection Principles






# LAWFULNESS OF PROCESSING

GDPR Art. 6 Processing shall be lawful only if and to the extent that at least one of the following applies:





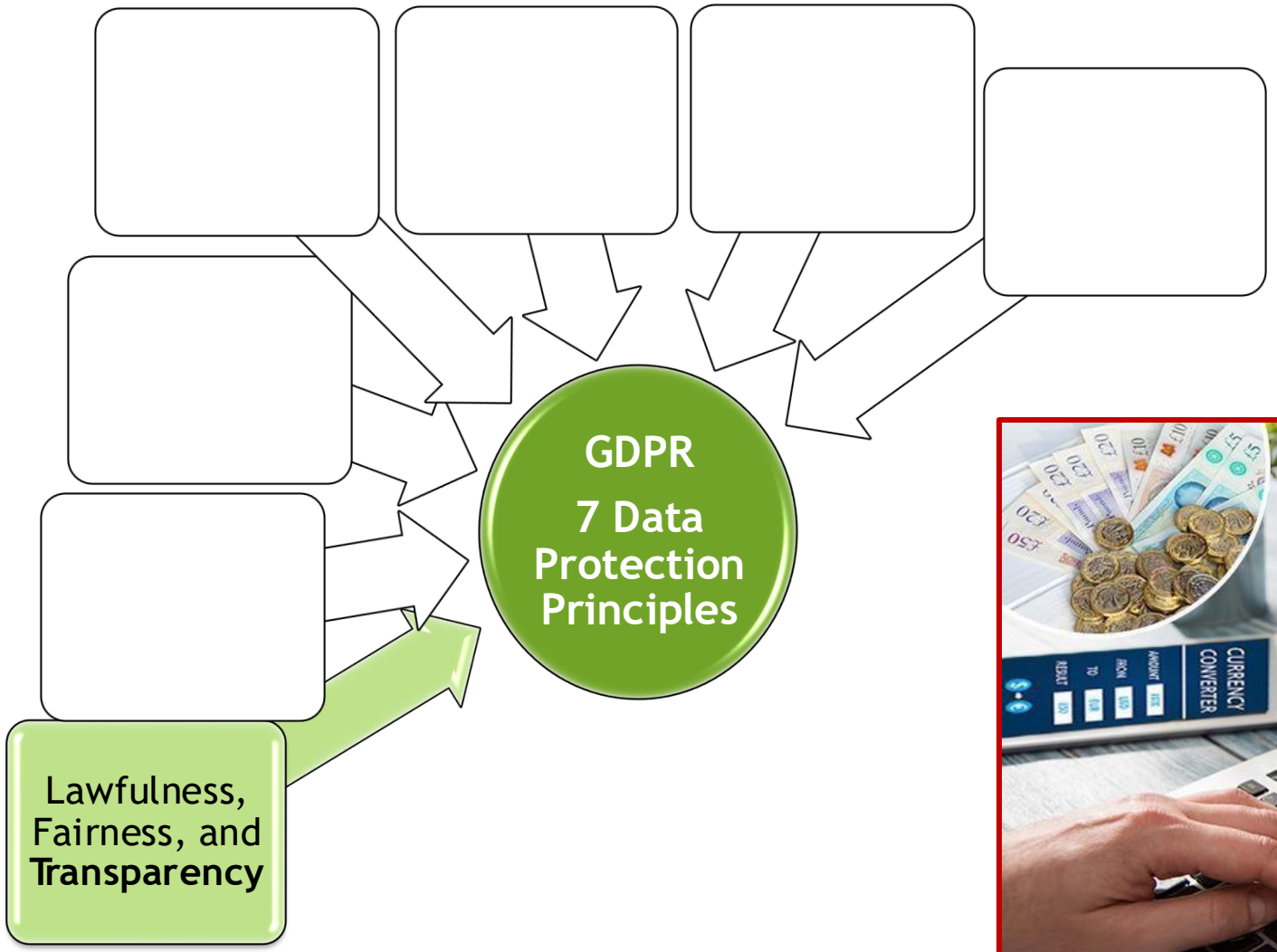

# CONDITIONS FOR CONSENT

GDPR Art. 7

- The controller must be able to prove consent
- Before consent is given, the data subject must be notified that they can withdraw consent
- If the consent is in writing, it must be clear, and no part may infringe on the GDPR
- The data subject can withdraw consent at any time, but this does not apply to anything processed while consent was active
- It determining if consent is given freely, issues such as contractual obligations or service conditions must be considered

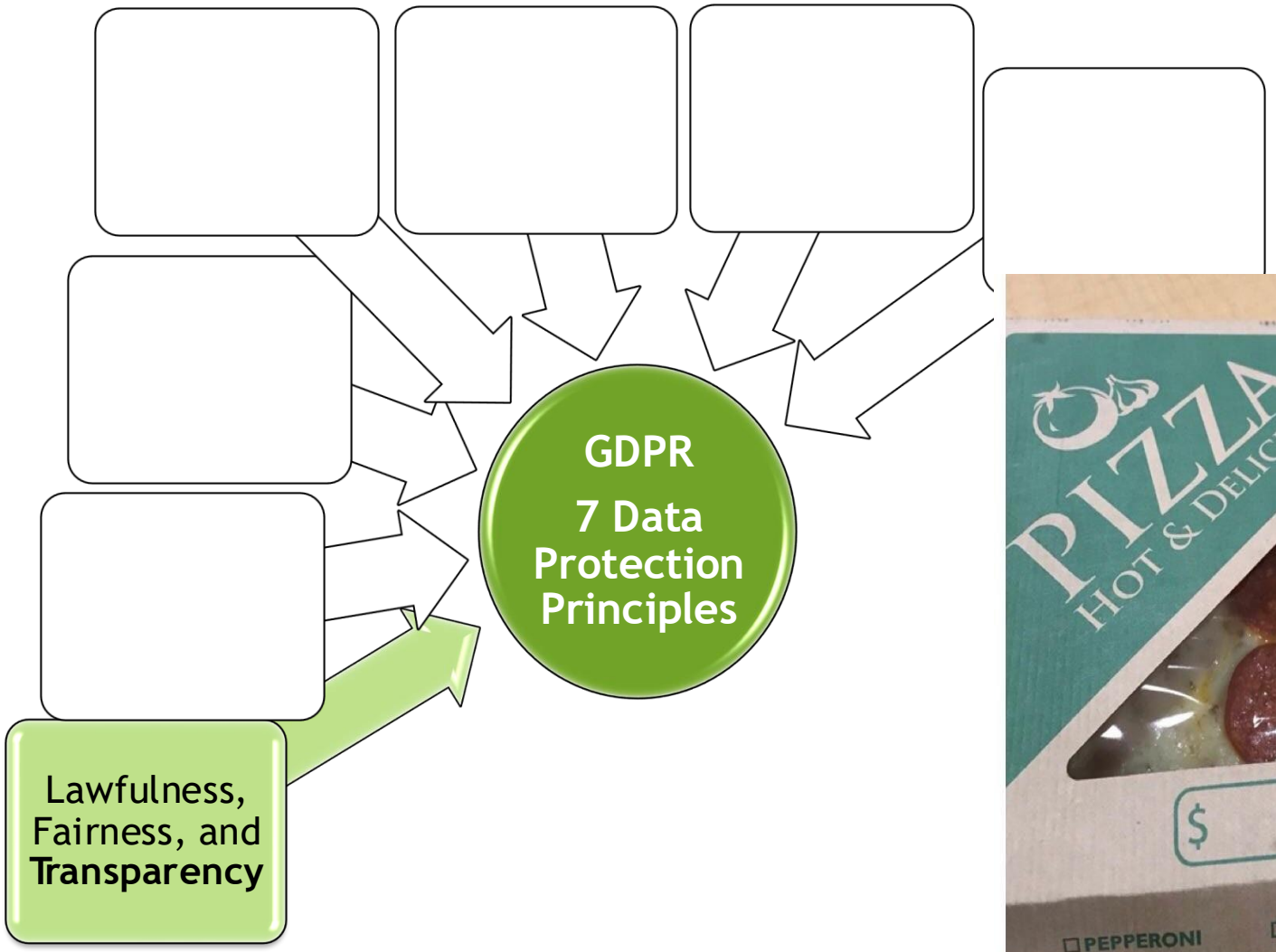


# GDPR Data Protection Principles



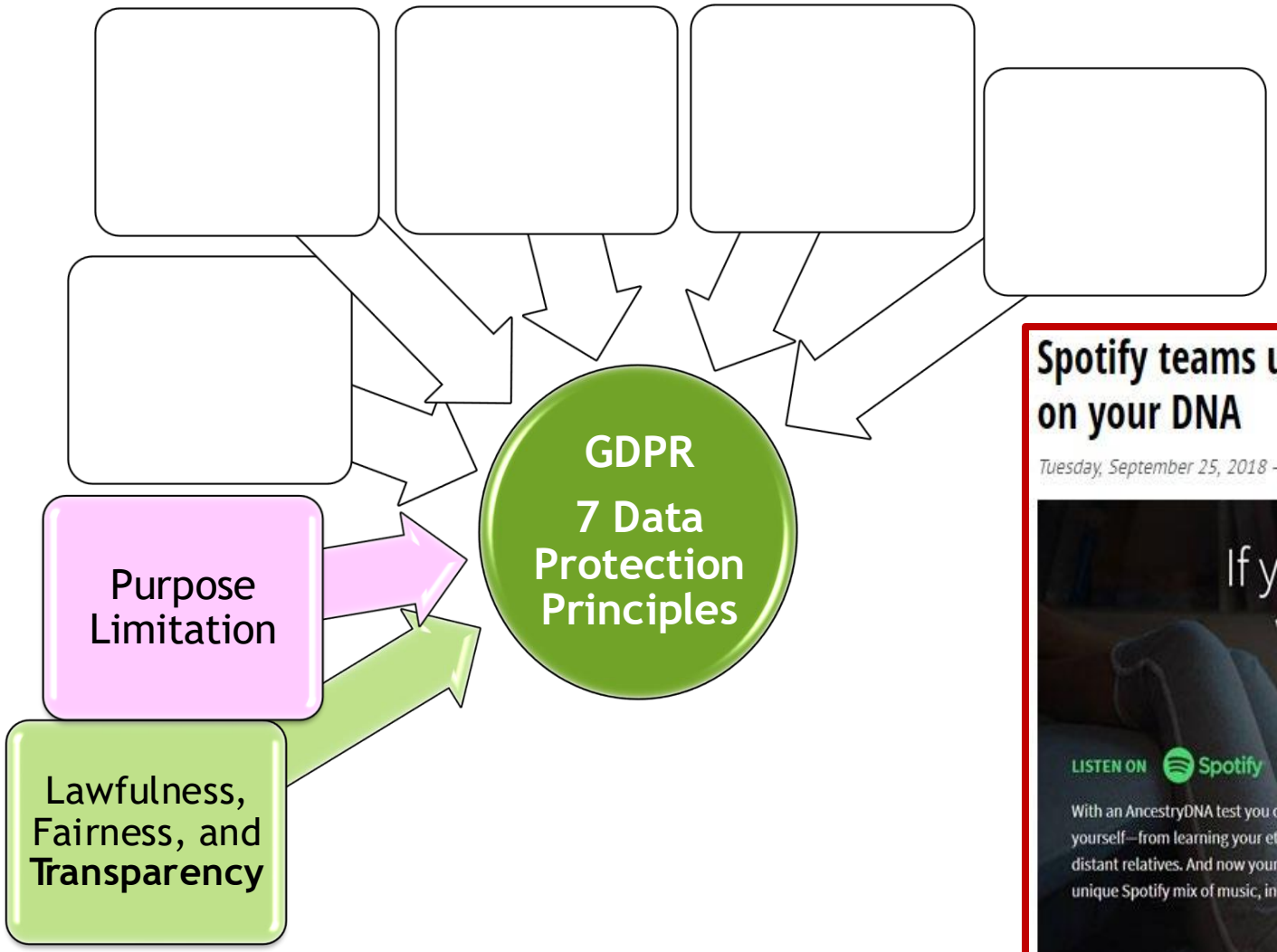



# GDPR Data Protection Principles






# GDPR Data Protection Principles

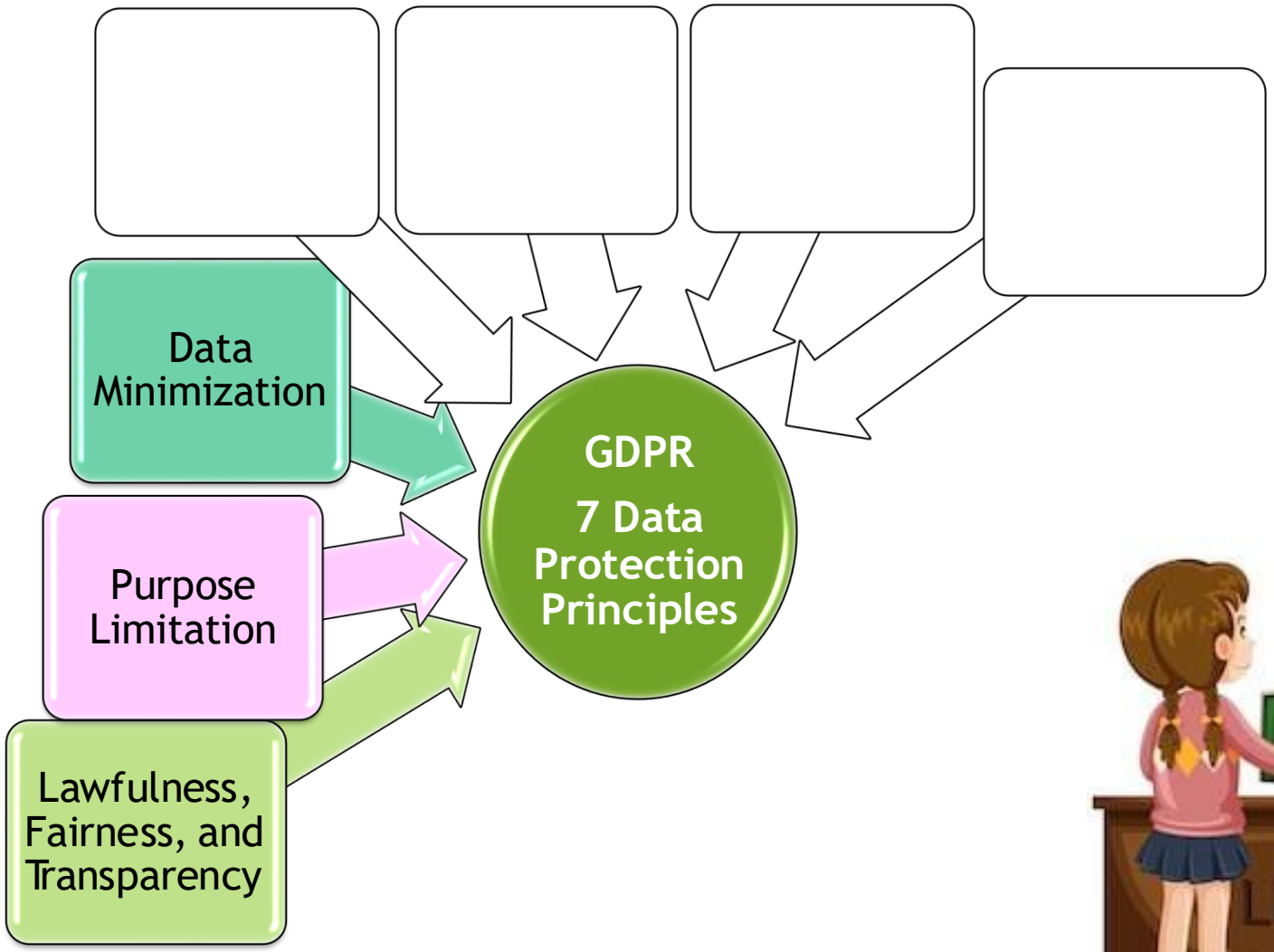



**Spotify teams up with Ancestry to create playlists based on your DNA**

*Tuesday, September 25, 2018 - 08:08 AM*

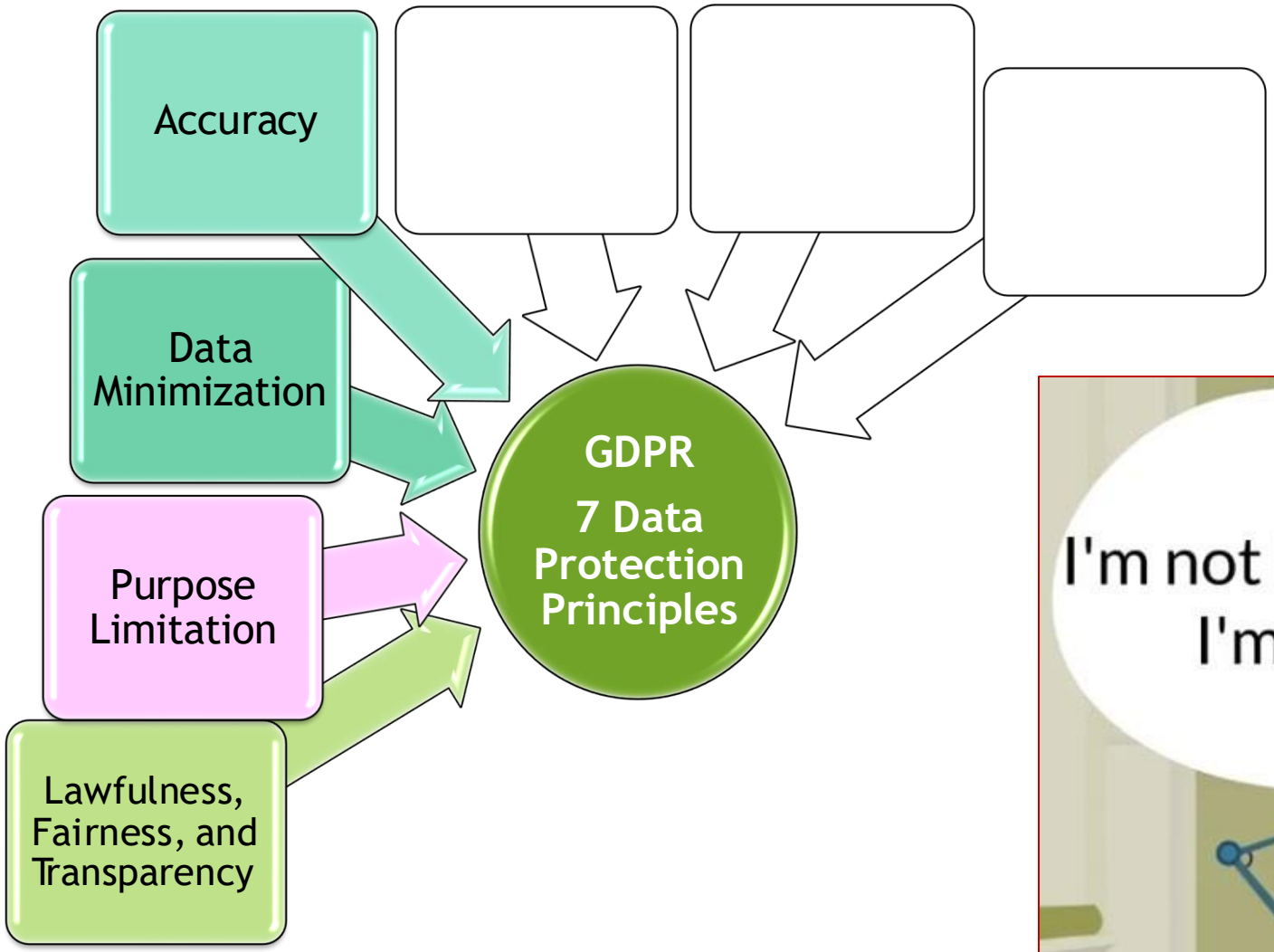


# GDPR Data Protection Principles



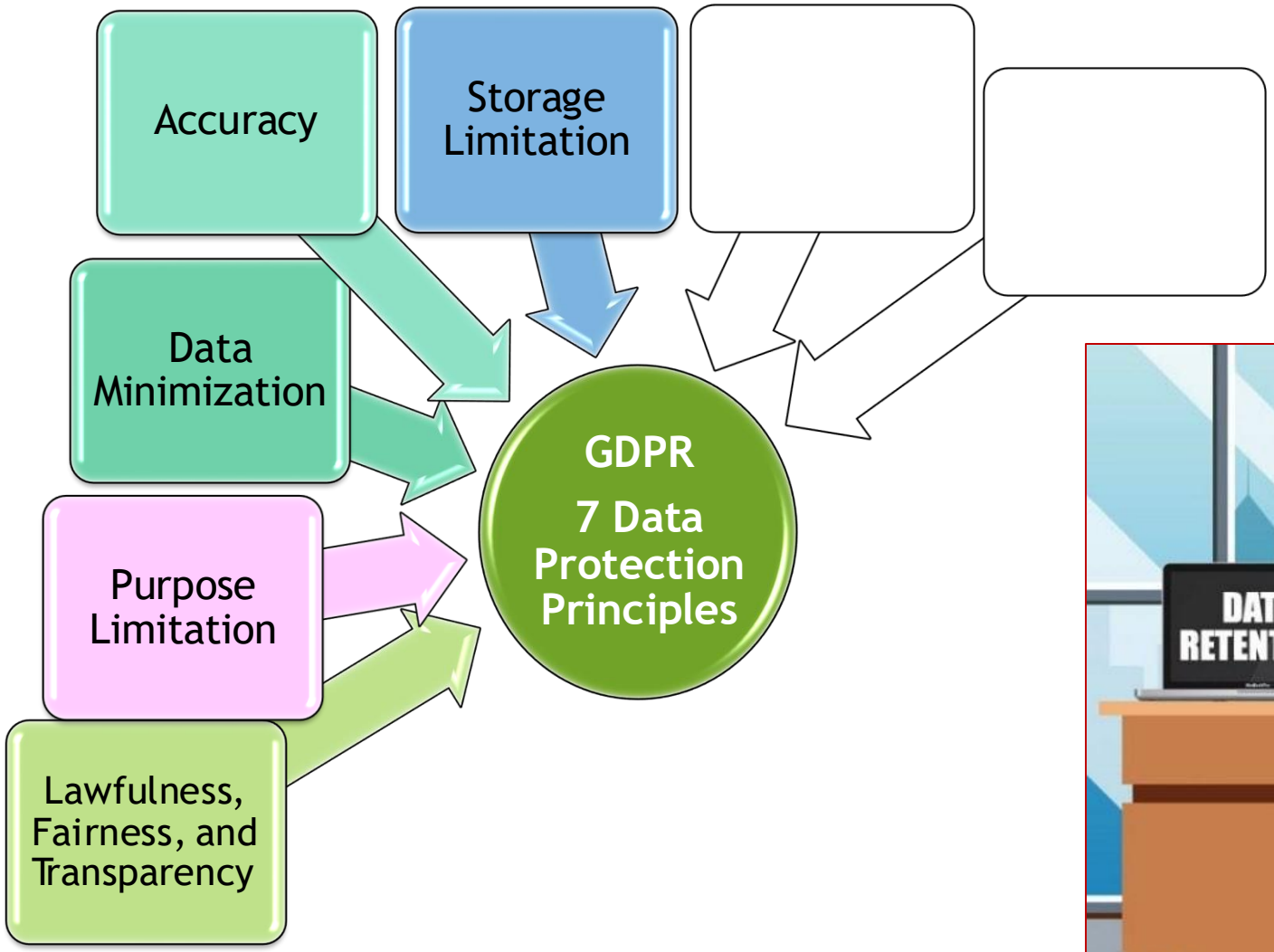



# GDPR Data Protection Principles



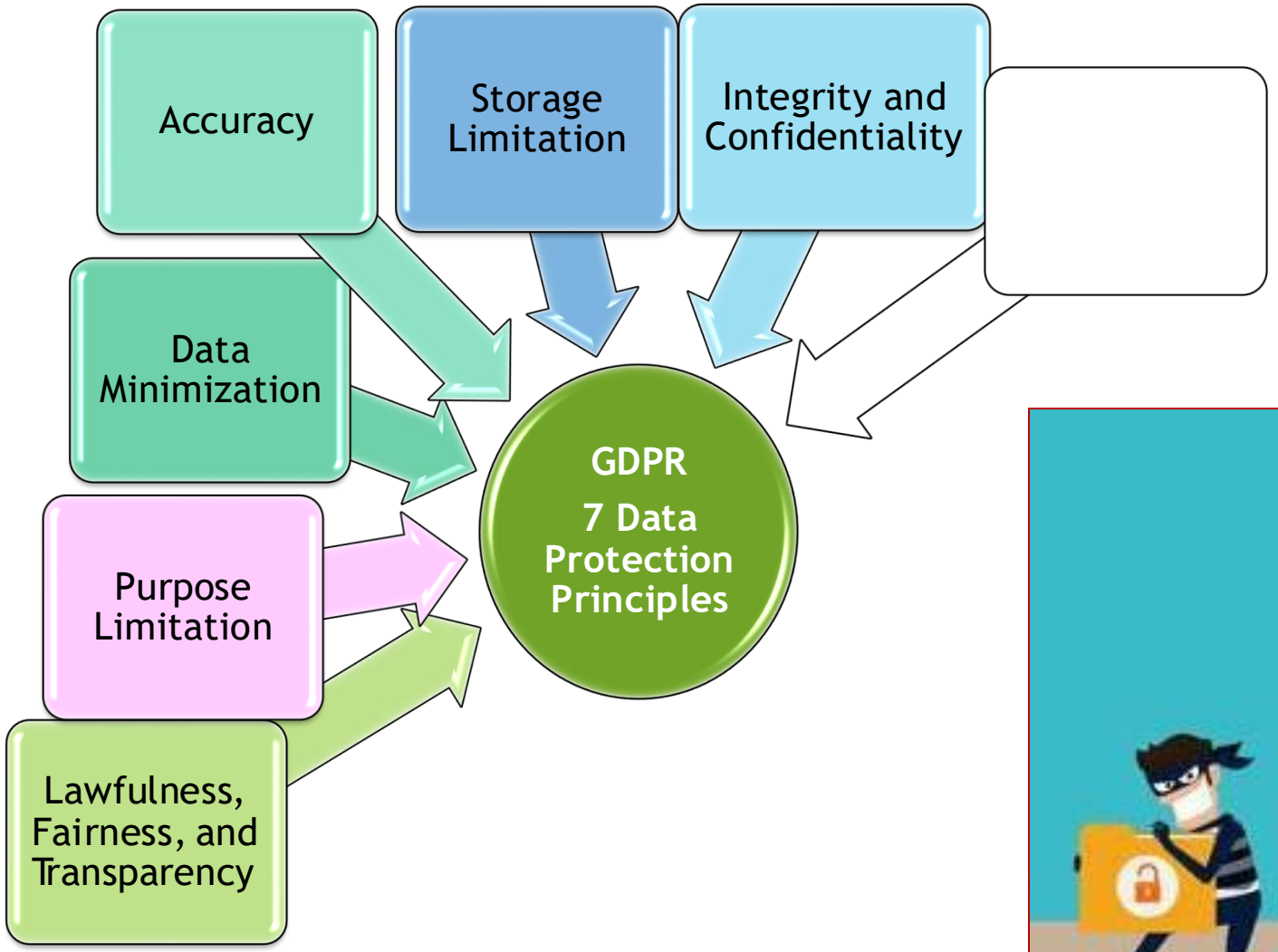



# GDPR Data Protection Principles



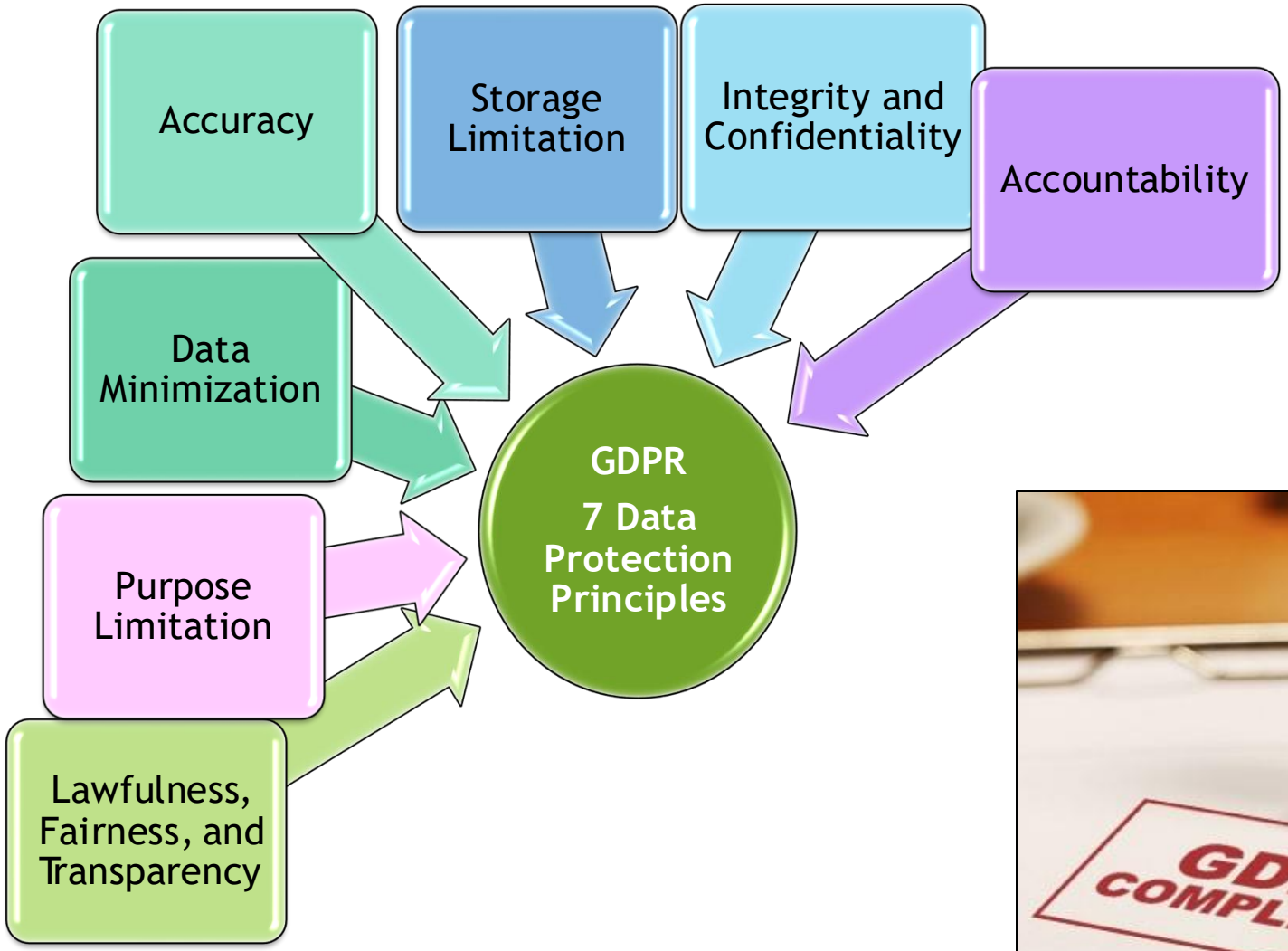



# GDPR Data Protection Principles






# GDPR Data Protection Principles






# RIGHTS OF THE DATA SUBJECT

Art. 12-23




https://plan.io/blog/gdpr-requirements-needed-for-compliance/

# PROCESSOR

Art. 28, 29

- A controller can only use **a processor that provides sufficient guarantees** that they will comply with the Regulations and protect the rights of data subjects
- A processor shall not engage another processor without permission of the controller
- **Processing by a processor must be governed by a contract** between the controller and processor which sets out the subject-matter and duration of the processing, the nature and purpose of the processing, the type of personal data involved, and the obligations and rights of the controller

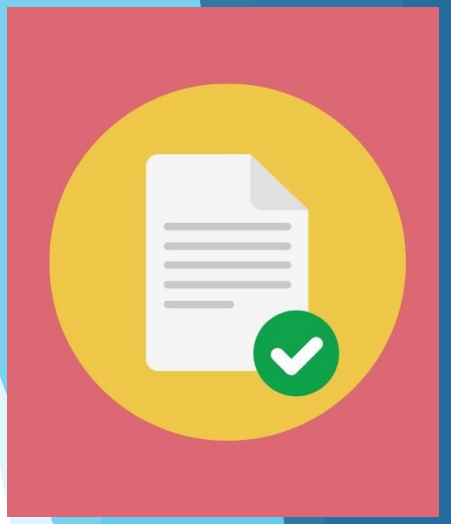
# THE PROCESSOR CONTRACT



Art. 28, 29

- Processing personal data may only **be done on documented instructions**, including taking account transferring data to a third country or international organisation
- The processor must be **committed to confidentiality**
- Take all **measures to comply with Article 32** (Security of Processing – encryption, pseudonymization, ensure CIA)
- Respect all **conditions** relating to **engaging another processor**
- Assist the controller in fulfilling their obligations in terms of Chapter III and Articles 32 to 36
- **Delete or return the personal data if requested by the controller** unless a law requires storage
- Make available to the controller everything necessary to **demonstrate compliance**

# RECORDS OF PROCESSING ACTIVITIES



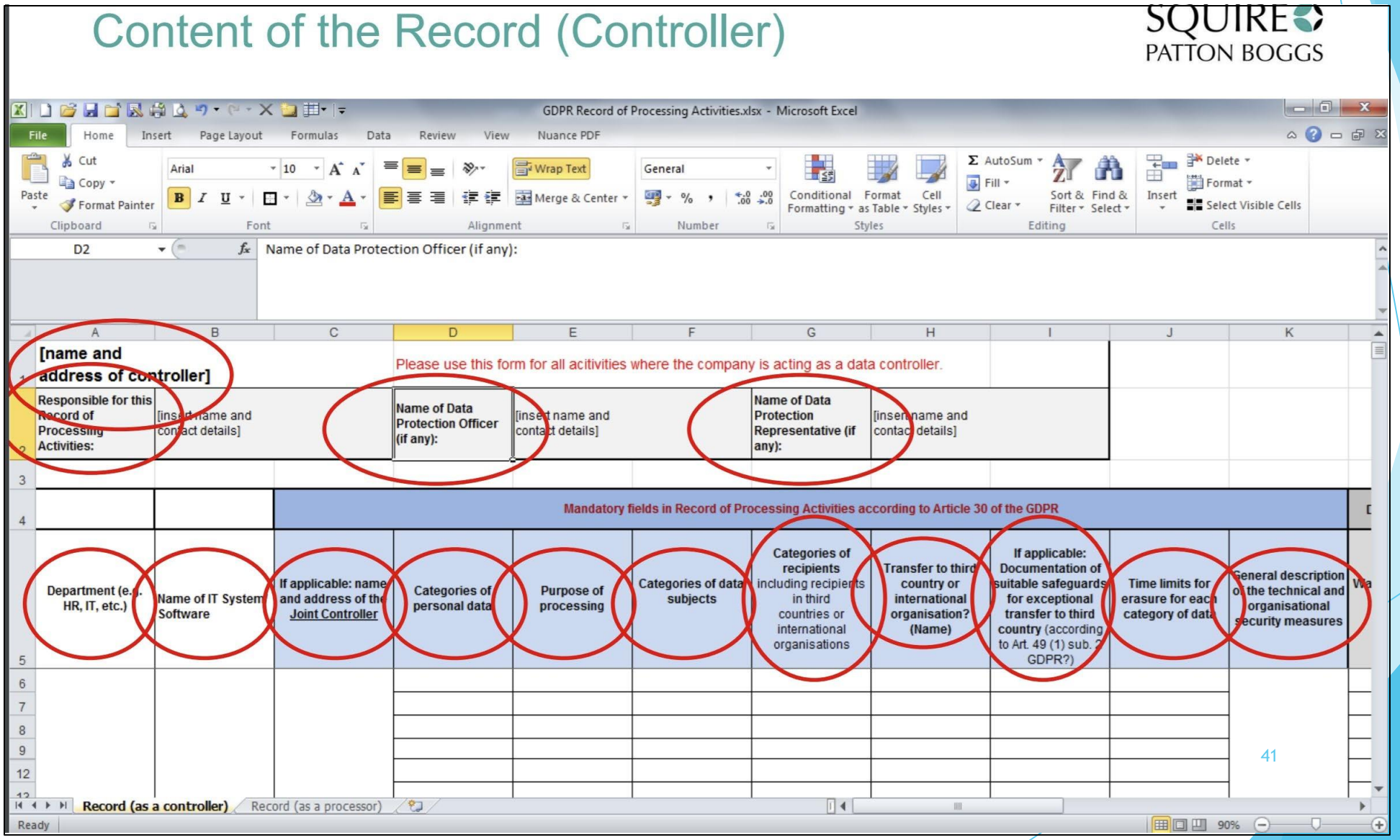
Art. 30

- **Each controller** and, […] **shall maintain a record of processing activities under its responsibility**. That **record shall contain** all of the following information:
  - the name and contact details of the controller and, where applicable, the joint controller, the controller's representative and the data protection officer;
  - the purposes of the processing;
  - a description of the categories of data subjects and of the categories of personal data;
  - the categories of recipients to whom the personal data have been or will be disclosed including recipients in third countries or international organisations;
  - where applicable, transfers of personal data to a third country or an international organisation, […] and, […], the documentation of suitable safeguards;
  - the envisaged time limits for erasure of the different categories of data;
  - where possible, a general description of the technical and organisational security measures referred to in Article 32(1).

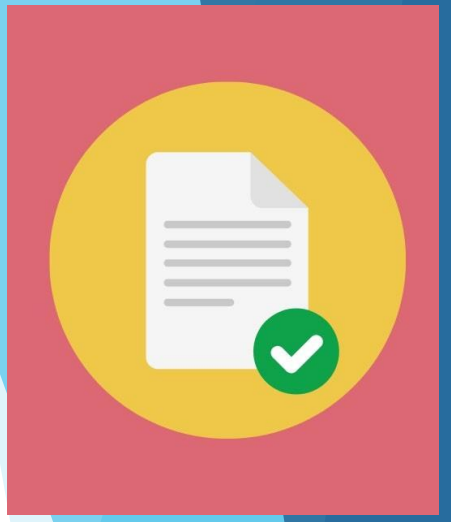
# RECORDS OF PROCESSING ACTIVITIES

## Content of the Record (Controller)

SQUIRE PATTON BOGGS



# RECORDS OF PROCESSING ACTIVITIES

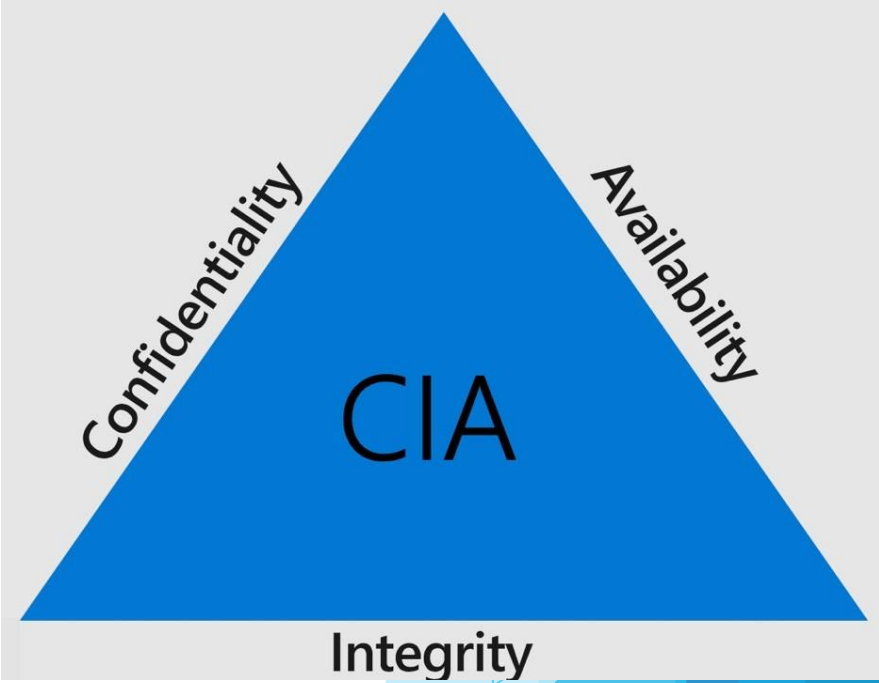


- Art. 30(2) **Each processor** and, where applicable, the processor's representative shall maintain a **record of all categories of processing activities carried out on behalf of a controller**, containing:
  - The name and contact details of the processor(s) and the controller on behalf of who they are acting, and where relevant the data protection officer
  - The categories of processing carried out on behalf of each controller
  - Where applicable transfers of data to a third country or international organisation, and the documentation of suitable safeguards
  - Where possible a general description of the technical and organisational security measures applied

# SECURITY OF PROCESSING

GDPR Art. 32

- The pseudonymisation and encryption of personal data
- The ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services
- The ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident
- A process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures for ensuring the security of processing



# SENSITIVE DATA

**Processing of special categories of personal data (Art.9)**

- Processing of personal data revealing
  - racial or ethnic origin,
  - political opinions,
  - religious or philosophical beliefs,
  - or trade union membership,
  - and the processing of genetic data,
  - biometric data for the purpose of uniquely identifying a natural person,
  - data concerning health or data concerning a natural person's sex life or sexual orientation

shall be prohibited

# Examples of special categories of personal data

Member States may maintain or introduce further conditions, including limitations, with regard to the processing of **genetic data, biometric data or data concerning health.**

## BIOMETRIC DATA

- facial recognition
- fingerprints
- voice recognition
- iris scanning
- palmprint verification
- retina recognition
- ear shape recognition

## HEALTH DATA

- patient medical history
- data on disability
- illnesses,
- medical diagnosis,
- medical treatment,
- medical opinions
- fitness tracker data

## GENETIC DATA

- chromosomal analysis
- DNA analysis
- RNA analysis

# GDPR and Ethics

- While individual EU-funded research projects processing personal data must comply with EU and national data protection laws, the objective of this guidance note is to ensure that, in addition to respecting legal obligations, **all projects are guided by ethical considerations and the values and principles on which the EU is founded.**
- Particular attention should be paid to research involving special categories of data (formerly known as 'sensitive data'), profiling, automated decision-making, data-mining techniques, big-data analytics and artificial intelligence, as such processing operations may pose higher risks to the rights and freedoms of data subjects






https://ec.europa.eu/info/sites/info/files/5._h2020_ethics_and_data_protection_0.pdf

# Informed consent and ethics

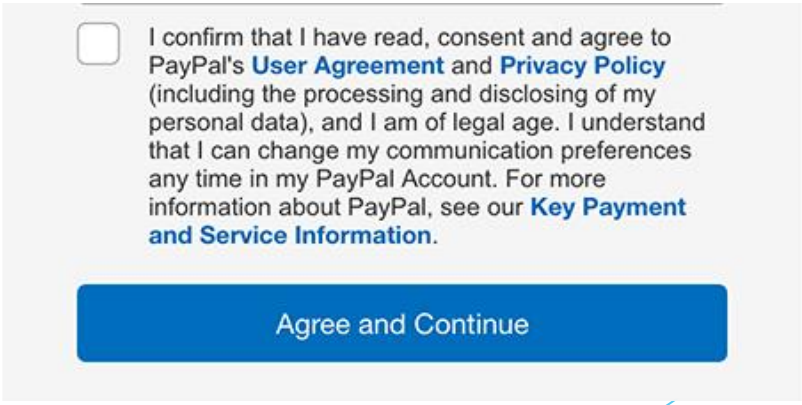
- **Informed consent is the cornerstone of research ethics.**
- Whenever you collect personal data directly from research participants, **you must seek** their informed consent by means of a procedure that **meets the minimum standards of the GDPR.**
- As with any research project involving human subjects, **if the data processing entails potential risks to the data subjects' rights and freedoms, they must be made aware of these risks** during the informed consent procedure.

# Consent

- The data subject consents to the processing of his or her personal data for one or more specific purposes. (Art.6(1)(a))
- "**consent**" of the data subject means any **freely given**, **specific**, **informed** and **unambiguous** indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her. (Art.4(11))
- **The acceptance can be by written / oral statement or other conduct** e.g. ticking a box, choosing technical settings etc. Silence, pre-ticked boxes or inactivity should not constitute consent. (Recital 32)

# Conditions for consent (Art.7):

- Where processing is based on consent, the controller must be able to **demonstrate that the data subject has consented** to processing of his or her personal data.
- **If** the data subject's consent is given in the context of a **written** declaration which also concerns other matters the request for consent must be presented in a manner which is **clearly distinguishable from the other matters**, in an **intelligible and easily accessible form, using clear and plain language**.



# Subject's rights related to consent

- The data subject must have **the right to withdraw his or her consent at any time**:
  - The withdrawal of consent **must not affect the lawfulness of the processing** based on consent before its withdrawal.
  - Prior to giving consent, the data subject must be informed of his or her right to withdraw consent.
  - It **must be** as **easy to withdraw** as to give consent.



# Consent

- When assessing whether consent is freely given, utmost account must be taken of whether the performance of a contract, including the provision of a service, is conditional on consent to the processing of personal data that is not necessary for the performance of that contract.
- **Processing of child's personal data -** consent may be obtained from a child aged 16 years or more, or a person holding parental responsibility. (Art.8)

# Rights, Supervision And Enforcement

- **Each Member State shall provide** for one or more **independent public authorities to be responsible for monitoring the application of this Regulation**, in order to protect the fundamental rights and freedoms of natural persons in relation to processing and to facilitate the free flow of personal data within the Union ('supervisory authority'). (Art 51)
- Member States shall provide for each member of their supervisory authorities (Art 53)



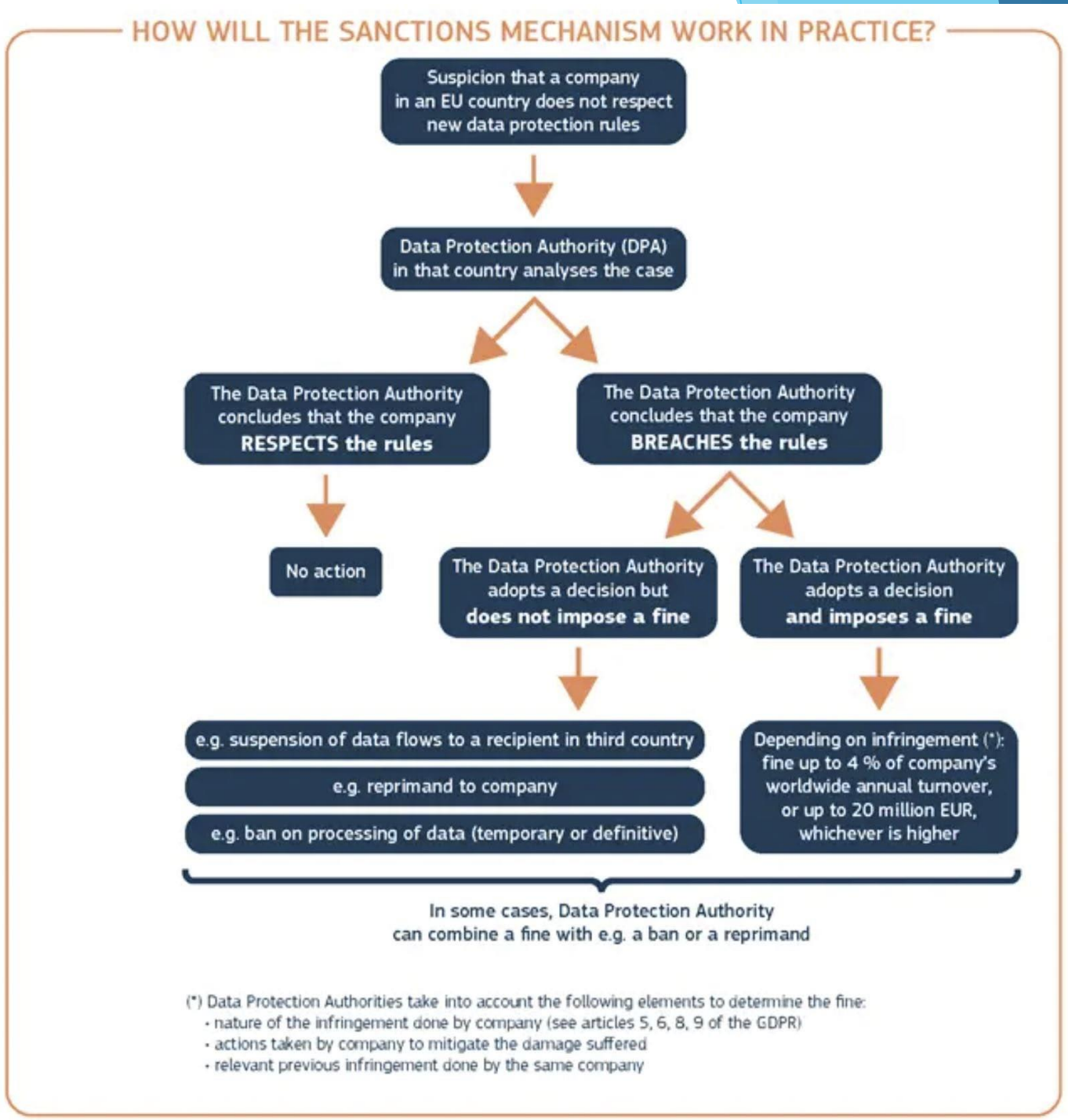
# Data Protection Commission

An Coimisiún um Chosaint Sonraí
Data Protection Commission

- The Data Protection Commission (DPC) was established by the Data Protection Acts 1988 to 2018. (Part 2, DPA 2018)
- Under the GDPR and the Data Protection Acts, the DPC is responsible for monitoring the application of the GDPR.
- The DPC's tasks include:
  - Monitoring and enforcing the application of the GDPR,
  - Promoting awareness and understanding of GDPR,
  - Providing information to and handling complaints of data subjects, and
  - Cooperating with other data protection authorities in other EU Member States. (Art.57 GDPR, s.12 DPA 2018)

# The role of the Data Protection Authority in sanctions

Figure illustrates the sanctions mechanism with the well-known administrative fines but most of all the role of the DPA



# Enforcement notice




- Where the DPC or an authorised officer ("AO") believes that a controller or processor is in breach of data protection law, it may serve an "**enforcement notice**" on the controller or processor, requiring it to take steps specified in the notice within a specific timeframe.
- The controller or processor may **appeal to the courts within 28 days**.

# Administrative Fines

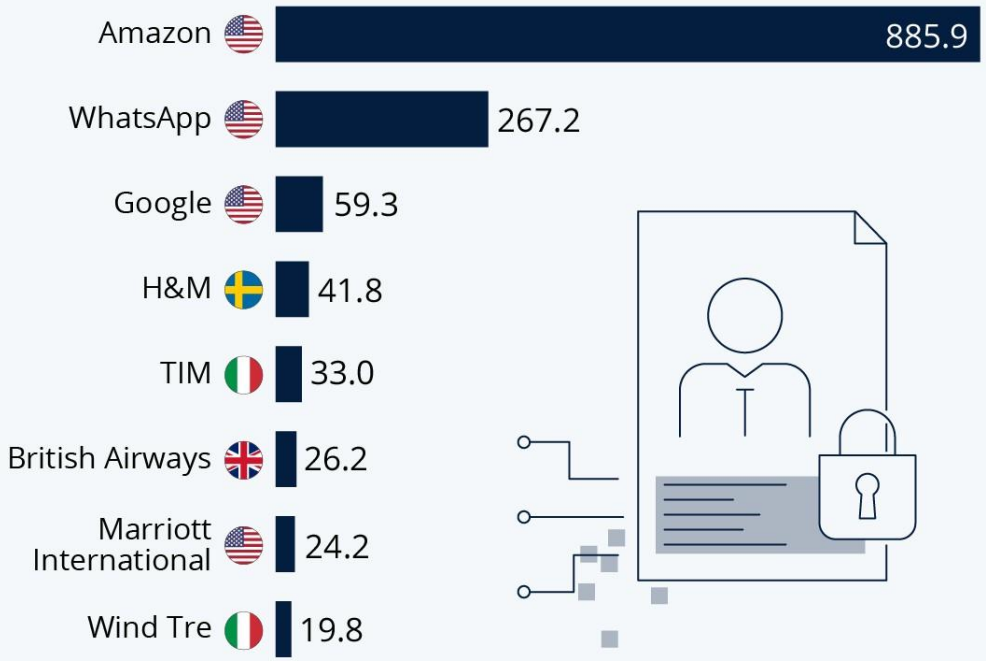
- The DPC may impose an administrative fine on a controller or processor. (s.141)
- The fine may be a maximum of €10,000,000 or 2% of the worldwide annual turnover for breaches of the governance and risk management requirements. (Art.83 GDPR)
- The fine may be a maximum of €20,000,000 or 4% of the worldwide annual turnover for breaches of the general data protection provisions. (Art.83 GDPR)



# Administrative Fines

## Big Tech, Big Fines

Highest fines for breaching one or more articles of the GDPR (in million U.S. dollars)




Source: CMS GDPR Enforcement Tracker

statista

## The Countries With The Most GDPR Data Breaches

Personal data breaches notified per EEA jurisdiction (May 25, 2018 to Jan 27, 2020)*

| | Total breaches | Breaches per 100,000 people |
|---|---|---|
| The Netherlands | 40,647 | 147.20 |
| Germany | 37,636 | 31.12 |
| United Kingdom | 22,181 | 17.79 |
| Ireland | 10,516 | 132.52 |
| Denmark | 9,806 | 115.43 |
| Poland | 7,478 | 13.74 |
| Sweden | 7,333 | 48.14 |
| Finland | 6,355 | 71.11 |
| France | 3,459 | 3.20 |
| Norway | 2,824 | 37.31 |

* EEA - European Economic Area (EU-28 + Norway, Iceland, Liechtenstein).
Source: DLA Piper



statista

# Case Study: Tusla – What Happened ?

- First in Ireland
- Organization disclosed children's information to unauthorized individuals on 3 different occasions.
- Very much a human error

Inquiries made by the DPC found that Tusla had infringed the GDPR in a number of ways by:

- disclosing the identify of a data subject to third parties (the breach itself)
- failing to notify the DPC of the breach without undue delay (infringing Article 33(1) of the GDPR)
- failing to implement organisational measures appropriate to the risk (as required under Article 32(1) of the GDPR), and
- failing to appropriately redact materials in contravention of Article 32(1) of the GDPR

TUSLA
An Ghníomhaireacht um Leanaí agus an Teaghlach
Child and Family Agency

# Case Study: Tusla – What They Could Have Done ?

- **Reduce the opportunities for this kind of thing**
- Changing your work practices, routines and technologies to systematically reduce the opportunity for error is the best way to start your mitigation efforts. While the way in which you achieve this will depend on the specific activities and environments of your business, there are some common guidelines to mitigating human error opportunities.
- **Privilege control:** ensure that your users only have access to the data and functionality that they need to perform their roles. This reduces the amount of information that will be exposed even if the user commits an error that leads to a breach.
- **Change your culture**
- **Encourage discussion.** One of the best ways to ensure that security stays at the forefront is to get people talking about it. Bring up discussion topics around security - and ensure that they are relevant to your end-users' day-to-day work activities so they are more likely to get engaged. This will help them see what they can each do personally to help keep up the security of your organisation.
- **Make it easy to ask questions.** As part of the learning process, your end-users will probably stumble into many situations where they are unsure of the security implications. In these situations, you would rather them ask you or someone else with knowledge rather than make a guess and risk making the wrong choice by themselves. Ensure that someone is always available to answer any questions from end-users in a friendly manner, and reward users who bring up good questions.
- **Use posters and reminders.** Security posters and tips serve as little reminders to help ensure that your end-users are thinking of security throughout their work day. A poster with information about strong passwords will, for example, allow users to easily see what the requirements are for keeping company accounts safe.
- **Address lack of knowledge with training**
- While reducing the opportunities for error is essential, you must also approach the causes of error from a human angle. Educating your employees on security basics and best practices allows them to make better decisions, and enables them to keep security on their mind and seek further guidance when they're not sure what the consequences of a certain action are.
- **Train employees on all core security topics**
- **Humans don't have to be the weakest link**

# Case Study: Tusla – What It Cost Them?

- First in Ireland
- Organization disclosed children's information to unauthorized individuals on 3 different occasions.
- The decision found that Tusla infringed Article 32(1) of the GDPR by failing to implement appropriate measures with regard to the redaction of documents.
- Total fine: € 75.000
- In May 2020 Tusla received another fine of € 40.000 after it sent a letter containing allegations of abuse to a third party who then uploaded it to social media.

TUSLA
An Ghníomhaireacht um Leanaí agus an Teaghlach
Child and Family Agency

# Exercise. GDPR Quiz

- Answer 9 questions

https://www.legal-island.ie/articles/ire/resources/quiz/2018/apr/gdpr-quiz/

- Find the number of article of the GDPR, which includes the answer of the question and explanation

